

Pinecastle - Cyber Risk Assessment

Total Risks	22
Critical Residual Risks	1
High Residual Risks	13
Open / Planned Actions	22
Top Residual Score	20
Assessment Date	2026-08-13

Residual Rating	Count	Management Meaning	Primary Action	Escalation
Critical	1	Immediate leadership decision	Escalate and fund	Executive
High	13	Prioritized remediation	Track to due date	CISO / owner
Medium	8	Managed through plan	Monitor	Control owner
Low	0	Routine monitoring	Maintain	Operational

Top Residual Risks	Business Process	Asset	Residual Score	Residual Rating	Treatment	Owner	Due Date
R-015	Incident Response	Enterprise Incident Process	20	Critical	Mitigate	CISO	2026-11-15
R-020	Audit Readiness	Security Evidence	16	High	Mitigate	GRC Lead	2026-12-31
R-001	Identity and Access Management	Okta / Microsoft 365 / AWS Admin	15	High	Mitigate	VP of IT	2026-10-15
R-002	Business Continuity	Production SaaS Platform	15	High	Mitigate	Director of Infrastructure	2026-11-30
R-003	Cloud Security	AWS S3 / IAM / Network Configurations	15	High	Mitigate	Cloud Engineering Manager	2026-10-31

Risk Scoring Methodology

Likelihood	Label	Definition
	1 Rare	Not expected, but possible under unusual circumstances
	2 Unlikely	Could occur, but not expected annually
	3 Possible	Could occur within the next year
	4 Likely	Expected or observed in comparable SaaS environments
	5 Almost Certain	Expected repeatedly or already occurring

Score Range	Rating	Management Meaning
1-4	Low	Monitor through normal operations
5-9	Medium	Track with named owner
10-16	High	Prioritize remediation and report to leadership
17-25	Critical	Immediate leadership decision required

Impact	Label	Definition
	1 Minimal	Limited internal inconvenience
	2 Minor	Some operational disruption or limited data exposure
	3 Moderate	Material process disruption, customer impact, or audit finding
	4 Major	Significant customer, legal, financial, or operational impact
	5 Severe	Major breach, prolonged outage, regulatory exposure, or board-level impact

Risk ID	Business Process	Asset	Threat	Vulnerability	Risk Statement	Inherent Likelihood	Inherent Impact	Inherent Score	Inherent Rating	Existing Controls	Control Effectiveness	Residual Likelihood	Residual Impact	Residual Score	Residual Rating	Treatment	Action Plan	Risk Owner	Due Date	Status	CSF Function	NIST 800-53 Ref	CIS / Other Ref	Display Rank
R-001	Identity and Access Management	Okta / Microsoft 365 / AWS Admin	Credential theft	Privileged MFA not consistently phishing-resistant	Unauthorized privileged access may occur because administrator authentication is not consistently hardened, leading to customer data exposure or service disruption.	5	5	25	Critical	MFA, SSO, audit logs	Partially Effective	3	5	15	High	Mitigate	Enforce phishing-resistant MFA for privileged accounts; complete quarterly privileged access review; remove stale admin accounts.	VP of IT	2026-10-15	In Progress	GOVERN, PROTECT	AC-2, IA-2	CIS 6, CIS 5	3
R-002	Business Continuity	Production SaaS Platform	Ransomware	Backup restoration not tested end-to-end	Ransomware or destructive malware may disrupt operations because recovery procedures have not been fully validated.	4	5	20	Critical	Endpoint protection, backups, logging	Partially Effective	3	5	15	High	Mitigate	Run backup restore test; confirm RTO/RPO; document executive recovery decision process.	Director of Infrastructure	2026-11-30	Planned	RESPOND, RECOVER	CP-9, CP-10, IR-4	CIS 11, CIS 17	4
R-003	Cloud Security	AWS S3 / IAM / Network Configurations	Cloud misconfiguration	Manual configuration review and inconsistent preventive guardrails	Customer data may be exposed because cloud storage, network, or IAM settings could be misconfigured without timely detection.	4	5	20	Critical	AWS IAM, logging, change review	Partially Effective	3	5	15	High	Mitigate	Implement cloud configuration monitoring; require security review for infrastructure changes; review public exposure alerts monthly.	Cloud Engineering Manager	2026-10-31	In Progress	IDENTIFY, PROTECT, DETECT	CM-2, AC-3, SI-4	CIS 4, CIS 12	5
R-004	Access Governance	SaaS Applications	Excessive privileges	Access reviews are inconsistent across business applications	Employees may retain excessive privileges because access is not reviewed consistently across SaaS applications.	4	4	16	High	Manager approvals, SSO groups	Partially Effective	3	4	12	High	Mitigate	Define app owners; conduct quarterly access reviews for critical SaaS apps; track exceptions.	GRC Lead	2026-12-15	Planned	GOVERN, PROTECT	AC-2, AC-6	CIS 5, CIS 6	7
R-005	Joiner-Mover-Leaver	Okta / SaaS Apps	Former employee access	Deprovisioning depends on timely HR termination notification; residual risk remains if that upstream trigger is delayed.	A delayed HR termination notification could leave a former employee with access before the otherwise operating removal workflow is triggered.	3	4	12	High	Fictional scenario assumption: SSO deactivation and retained termination records operate consistently when HR notification is received.	Effective	2	4	8	Medium	Mitigate	Maintain automated deprovisioning and monthly termination sampling; monitor timeliness of HR notification.	People Operations Manager	2026-09-30	In Progress	PROTECT	AC-2, PS-4	CIS 5	17
R-006	Vendor Management	Critical SaaS Vendors	Vendor outage	Critical vendor continuity requirements not reviewed annually	A critical SaaS vendor outage may disrupt customer support or operations because continuity expectations are not reviewed.	3	4	12	High	Vendor contracts, status pages	Partially Effective	3	3	9	Medium	Transfer / Mitigate	Tier vendors; document continuity requirements; review SOC reports and BCP statements annually.	Procurement Manager	2027-01-15	Not Started	GOVERN, IDENTIFY	SR-3, CP-2	CIS 15	15
R-007	Third-Party Risk	Customer Data Processors	Third-party breach	Vendor security reviews are inconsistent by risk tier	Customer data may be exposed through a vendor breach because critical vendors are not assessed with consistent due diligence.	4	5	20	Critical	Contract review, limited questionnaires	Partially Effective	3	5	15	High	Mitigate	Implement NIST SP 800-161-aligned vendor tiering; require annual critical vendor reviews.	GRC Lead	2026-12-31	Planned	GOVERN, IDENTIFY	SR-3, SR-6	CIS 15	6
R-008	Data Protection	Backups / Data Stores	Backup failure	Backup monitoring lacks periodic restore evidence	Critical data may not be recoverable because backups are monitored but restoration is not periodically evidenced.	3	5	15	High	Automated backups	Partially Effective	2	5	10	High	Mitigate	Schedule quarterly restore testing and document results.	Director of Infrastructure	2026-11-30	Planned	RECOVER	CP-9, CP-10	CIS 11	13
R-009	Vulnerability Management	Production Systems	Known vulnerability exploitation	Remediation SLAs are not consistently enforced	Attackers may exploit known vulnerabilities because critical findings do not always meet remediation SLAs.	4	4	16	High	Scanning, patching	Partially Effective	3	4	12	High	Mitigate	Approve remediation SLA; report overdue critical vulnerabilities; document risk exceptions.	Security Engineer	2026-10-31	In Progress	IDENTIFY, PROTECT	RA-5, SI-2	CIS 7	8
R-010	Email Security	Microsoft 365	Phishing / BEC	User reporting and simulation metrics are immature	Business email compromise may occur because phishing resilience and reporting metrics are not mature.	4	4	16	High	Email filtering, MFA, awareness training	Partially Effective	3	4	12	High	Mitigate	Run quarterly phishing simulation; track reporting rate; tune mailbox protections.	Security Awareness Owner	2026-12-01	Planned	PROTECT, DETECT	AT-2, SI-4	CIS 14, CIS 9	9
R-011	Secure SDLC	GitHub Repositories	Source-code exposure	Repository access and secret scanning exceptions not centrally reviewed	Source code or secrets may be exposed because repository access and secret scanning exceptions are not consistently reviewed.	3	5	15	High	GitHub access controls, branch protection	Partially Effective	2	5	10	High	Mitigate	Review repo access quarterly; enforce secret scanning; document exceptions.	Engineering Manager	2026-11-15	Planned	PROTECT, DETECT	SA-10, CM-5	CIS 16	14
R-012	Security Monitoring	Cloud and SaaS Logs	Insufficient logging	Log coverage and alert ownership are not formally mapped	Security incidents may go undetected because key logs and alert owners are not fully documented.	4	4	16	High	Cloud logs, SaaS logs, endpoint telemetry	Partially Effective	3	4	12	High	Mitigate	Map critical logs; define alert owners; test alert routing monthly.	Security Operations Lead	2026-10-31	In Progress	DETECT	AU-6, SI-4	CIS 8	10
R-013	Patch Management	Endpoints / Servers	Unpatched critical vulnerability	Patch compliance evidence is incomplete	Critical vulnerabilities may remain exploitable because patch compliance is not consistently evidenced.	4	4	16	High	Endpoint management, scanning	Partially Effective	3	4	12	High	Mitigate	Create monthly patch compliance report and exception workflow.	IT Operations Manager	2026-10-15	In Progress	PROTECT	SI-2	CIS 7	11
R-014	Vendor Governance	New Vendors	Weak due diligence	No formal inherent-risk questionnaire before onboarding	High-risk vendors may be onboarded without appropriate review because inherent risk is not assessed before contracting.	3	4	12	High	Procurement review	Partially Effective	3	3	9	Medium	Mitigate	Add vendor inherent-risk intake; route high-risk vendors to security review.	Procurement Manager	2026-09-30	Planned	GOVERN	SR-3	CIS 15	16
R-015	Incident Response	Enterprise Incident Process	Untested response plan	No recent tabletop exercise	Incident response may be delayed or inconsistent because roles, escalation paths, and communications have not been exercised.	4	5	20	Critical	IR plan and on-call rotation exist, but no current exercise validates coordinated response. No demonstrated reduction credited to these controls for this risk.	Ineffective	4	5	20	Critical	Mitigate	Run tabletop aligned to NIST SP 800-61 Rev. 3; capture lessons learned and corrective actions.	CISO	2026-11-15	Planned	RESPOND	IR-3, IR-4	CIS 17	1
R-016	Data Governance	Customer Data	Excessive retention	Retention rules are not consistently mapped to systems	Customer data may be retained longer than required because retention rules are not mapped and tested across systems.	3	4	12	High	Contract terms, manual deletion	Partially Effective	2	4	8	Medium	Mitigate	Create data retention matrix; sample deletion evidence; align with privacy commitments.	Legal / Privacy Owner	2027-01-31	Not Started	GOVERN, IDENTIFY	PT-2, SI-12	CIS 3	18
R-017	Disaster Recovery	Production Platform	Failed DR	DR exercise not performed in last 12 months	Pinecastle may fail to restore service within customer expectations because disaster recovery has not been exercised.	3	5	15	High	Backups, infrastructure-as-code	Partially Effective	3	4	12	High	Mitigate	Conduct DR exercise; document RTO/RPO achievement and gaps.	Director of Infrastructure	2027-02-28	Not Started	RECOVER	CP-4, CP-10	CIS 11	12
R-018	Change Management	Production Changes	Unauthorized production change	An unauthorized change can still bypass the normal approval path; retrospective review is a detective control.	An unauthorized production change could cause exposure before review detects it, despite consistently operating approvals and emergency post-review.	3	4	12	High	Fictional scenario assumption: pull-request approvals and emergency reviews within five business days operate consistently.	Effective	2	4	8	Medium	Mitigate	Maintain production approvals and five-business-day emergency review; sample changes monthly.	Engineering Manager	2026-12-15	Planned	PROTECT	CM-3	CIS 4	19
R-019	Security Training	Workforce	Human error	Training completion evidence is incomplete for contractors	Security incidents may result from human error because awareness training coverage is not fully evidenced for contractors.	3	3	9	Medium	Annual training	Partially Effective	2	3	6	Medium	Mitigate	Extend training tracker to contractors; report overdue completion monthly.	People Operations Manager	2026-10-31	In Progress	PROTECT	AT-2	CIS 14	21
R-020	Audit Readiness	Security Evidence	Missing evidence	Control evidence is decentralized	Customer assurance or future SOC 2 readiness may be delayed because control evidence is not centrally organized.	4	4	16	High	Shared folders and ticketing lack central evidence ownership and review; they do not meet the evidence-governance objective.	Ineffective	4	4	16	High	Mitigate	Create evidence inventory; assign evidence owners; establish monthly evidence review for key controls.	GRC Lead	2026-12-31	Planned	GOVERN	CA-2, CA-7	SOC 2 CC2, CC3, CC5	2

Risk ID	Residual Rating	Action Plan	Owner	Due Date	Status	Priority	Notes
R-001	High	Enforce phishing-resistant MFA for privileged accounts; complete quarterly privileged access review; remove stale admin accounts.	VP of IT	2026-10-15	In Progress	High	Track in monthly GRC remediation review
R-002	High	Run backup restore test; confirm RTO/RPO; document executive recovery decision process.	Director of Infrastructure	2026-11-30	Planned	High	Track in monthly GRC remediation review
R-003	High	Implement cloud configuration monitoring; require security review for infrastructure changes; review public exposure alerts monthly.	Cloud Engineering Manager	2026-10-31	In Progress	High	Track in monthly GRC remediation review
R-004	High	Define app owners; conduct quarterly access reviews for critical SaaS apps; track exceptions.	GRC Lead	2026-12-15	Planned	High	Track in monthly GRC remediation review
R-005	Medium	Maintain automated deprovisioning and monthly termination sampling; monitor timeliness of HR notification.	People Operations Manager	2026-09-30	In Progress	Medium	Track in monthly GRC remediation review
R-006	Medium	Tier vendors; document continuity requirements; review SOC reports and BCP statements annually.	Procurement Manager	2027-01-15	Not Started	Medium	Track in monthly GRC remediation review
R-007	High	Implement NIST SP 800-161-aligned vendor tiering; require annual critical vendor reviews.	GRC Lead	2026-12-31	Planned	High	Track in monthly GRC remediation review
R-008	High	Schedule quarterly restore testing and document results.	Director of Infrastructure	2026-11-30	Planned	High	Track in monthly GRC remediation review
R-009	High	Approve remediation SLA; report overdue critical vulnerabilities; document risk exceptions.	Security Engineer	2026-10-31	In Progress	High	Track in monthly GRC remediation review
R-010	High	Run quarterly phishing simulation; track reporting rate; tune mailbox protections.	Security Awareness Owner	2026-12-01	Planned	High	Track in monthly GRC remediation review
R-011	High	Review repo access quarterly; enforce secret scanning; document exceptions.	Engineering Manager	2026-11-15	Planned	High	Track in monthly GRC remediation review
R-012	High	Map critical logs; define alert owners; test alert routing monthly.	Security Operations Lead	2026-10-31	In Progress	High	Track in monthly GRC remediation review
R-013	High	Create monthly patch compliance report and exception workflow.	IT Operations Manager	2026-10-15	In Progress	High	Track in monthly GRC remediation review
R-014	Medium	Add vendor inherent-risk intake; route high-risk vendors to security review.	Procurement Manager	2026-09-30	Planned	Medium	Track in monthly GRC remediation review
R-015	Critical	Run tabletop aligned to NIST SP 800-61 Rev. 3; capture lessons learned and corrective actions.	CISO	2026-11-15	Planned	Critical	Critical residual 20. Escalate to leadership; tabletop and corrective-action evidence required before crediting risk reduction.
R-016	Medium	Create data retention matrix; sample deletion evidence; align with privacy commitments.	Legal / Privacy Owner	2027-01-31	Not Started	Medium	Track in monthly GRC remediation review
R-017	High	Conduct DR exercise; document RTO/RPO achievement and gaps.	Director of Infrastructure	2027-02-28	Not Started	High	Track in monthly GRC remediation review
R-018	Medium	Maintain production approvals and five-business-day emergency review; sample changes monthly.	Engineering Manager	2026-12-15	Planned	Medium	Track in monthly GRC remediation review
R-019	Medium	Extend training tracker to contractors; report overdue completion monthly.	People Operations Manager	2026-10-31	In Progress	Medium	Track in monthly GRC remediation review
R-020	High	Create evidence inventory; assign evidence owners; establish monthly evidence review for key controls.	GRC Lead	2026-12-31	Planned	High	Residual 16 equals inherent: existing storage tools do not constitute an effective evidence-governance process.

Reference	URL	Use in Workbook
NIST CSF 2.0	https://www.nist.gov/cyberframework	Primary program framework and functions
NIST SP 800-30 Rev. 1	https://csrc.nist.gov/pubs/sp/800/30/r1/final	Risk-assessment methodology
NIST IR 8286 Rev. 1	https://csrc.nist.gov/pubs/ir/8286/r1/final	Cybersecurity risk integration with ERM
NIST IR 8286A Rev. 1	https://csrc.nist.gov/pubs/ir/8286/a/r1/final	Risk identification and estimation for ERM
NIST IR 8286C Rev. 1	https://csrc.nist.gov/pubs/ir/8286/c/r1/final	Risk staging and governance oversight
NIST SP 1308	https://csrc.nist.gov/pubs/sp/1308/final	CSF 2.0, ERM, and workforce management
NIST SP 800-53 Rev. 5 Release 5.2.0	https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls	Control catalog reference
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final	Control assessment reference
NIST SP 800-161 Rev. 1 Update 1	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Supply-chain risk reference
CIS Controls v8.1	https://www.cisecurity.org/controls/v8-1	Prioritized safeguards
ISO/IEC 27001:2022/Amd 1:2024	https://www.iso.org/standard/88435.html	ISMS requirements
ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	Security control guidance
AICPA TSC revised points of focus 2022	https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022	SOC 2 criteria reference
NIST SP 800-61 Rev. 3	https://csrc.nist.gov/pubs/sp/800/61/r3/final	Incident response
NIST SP 800-171 Rev. 3	https://csrc.nist.gov/pubs/sp/800/171/r3/final	CUI reference where relevant
ISO/IEC 27017:2026	https://www.iso.org/standard/43757.html	Cloud-specific control guidance
PCI DSS v4.0.1	https://www.pcisecuritystandards.org/document_library/	Payment-card reference where relevant
Scenario dates and rating definitions	Fictional assessment assumptions; see shared company profile	../00-company-profile/Pinecastle-Company-and-GRC-Scope.md